

생성형 AI 연계 이용 보안대책 평가 절차 안내

(금융보안원, '25.1.14.)

I. 평가 개요

- (평가대상·범위) 혁신금융서비스 조건부 인가를 받은 금융회사 등의 서비스 개시 전 생성형 AI 연계 이용 보안대책 수립·이행 여부를 평가

《「2024년 제13차 혁신금융서비스 지정 공고」(금융위, '24.12.13.) 내 관련 내용》

6. 부가조건

- ❶ 규제 특례사항에 대해 보안위협에 대비한 보안 요건을 준수할 것
 - (보안대책) **생성형 AI모델 연계** 시 망분리 예외 허용으로 인해 발생 가능한 보안 위협으로부터 소비자를 보호하기 위해 **보안대책***을 자체적으로 수립·이행할 것
 - * ①생성형 AI 운영·관리 보안대책, ②생성형 AI 모델(입력정보에 가명정보 유무 포함)의 보안대책, ③내부 단말기 보안대책(모바일 포함), ④내부망↔외부 AI 모델 연계 네트워크 보안대책(암호화 등)
 - **서비스 개시 전에 신청자가 수립한 보안대책 및 이행 여부에 대해 침해사고 대응기관(금융보안원 등)으로부터 확인받고, 그 결과를 금융위원회 및 금융감독원에 제출할 것**

- (평가시기) 혁신금융서비스 지정 후 서비스 개시 전 신청·평가

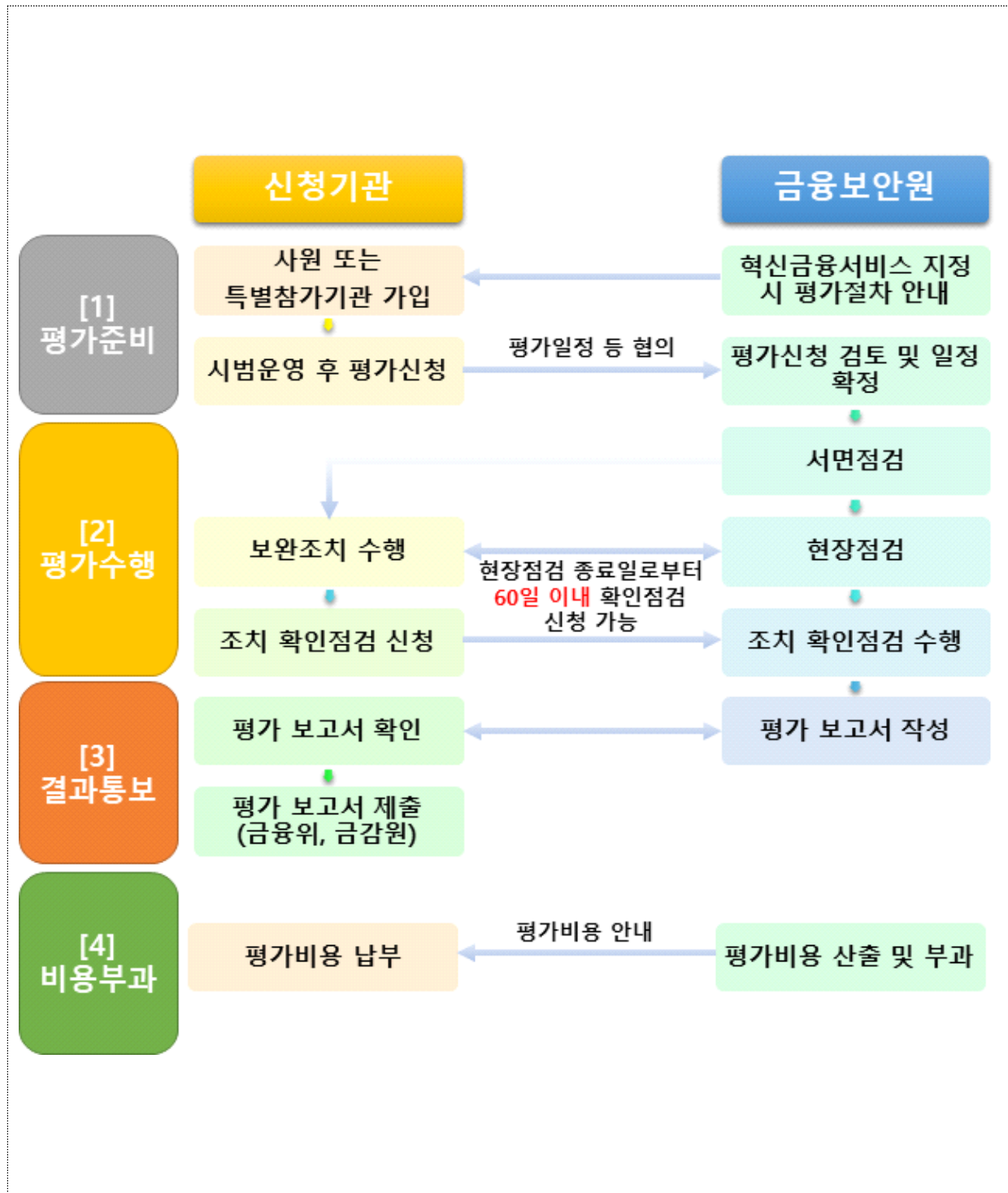
- (평가항목) ①생성형 AI 운영·관리 보안대책(6개), ②생성형 AI 모델 보안대책(8개), ③내부 단말기 보안대책(4개), ④내·외부 AI 모델 연계 네트워크 보안대책(2개)의 4개 분야, 20개 항목으로 구성

※ <별첨1> 생성형 AI 연계 이용 보안대책 평가기준 참조

- (평가방식) 서면 및 현장점검을 병행하는 2단계 점검체제로 평가

II. 생성형 AI 연계 이용 보안평가 절차

1 평가준비 → 2 평가수행 → 3 결과통보 → 4 비용부과 단계로 진행



1 평가준비 단계

① **(가입)** 혁신금융서비스 조건부 지정을 받았으나 금융보안원에 사원으로 가입되어 있지 않은 기관은 평가 신청 전 사원 또는 특별참가기관으로 가입 필요

- 사원가입을 희망하는 기관은 budget@fsec.or.kr로 문의가 필요하고 특별참가를 희망하는 기관은 내부망 SaaS 이용 보안대책 평가 절차 안내 中 특별참가 신청 관련 절차 활용

② **(평가신청)** 신청기관은 자체 보안대책을 시범운영*하고, 자체 보안대책 점검결과 및 신청서를 포함하여 평가신청

- <별첨2> 생성형 AI 연계 이용 보안대책 평가 신청서 및 <별첨3> 보안대책 이행서(증거자료 포함)를 금융보안원 앞 제출(aitech@fsec.or.kr)

* 서비스 운영 전 임시적으로 관련 시스템을 구축하여 운영한 결과를 토대로 자체점검

- 금융보안원은 반출이 불가능한 자료 및 파일 형태로 생성이 불가능한 자료의 경우 별도 확인(현장점검 시 확인)
- 금융보안원은 신청서 접수 후 평가일정 협의 및 비용 안내 가능

※ 평가 소요적수(M/D) 산정 기준

구분	소요적수 산정 기준	소요적수
대형	총자산 10조원 이상이고, 상시 종업원 수가 1,000명 이상	12
중형	총자산 2조원 이상이고, 상시 종업원 수가 300명 이상	10
소형	총자산 2조원 미만 또는 상시 종업원 수가 300명 미만	8

③ **(제출서류 검토)** 금융보안원은 신청기관이 제출한 자체점검 결과, 증거자료 등 제출서류의 적정성 검토

- 신청기관이 제출한 서류가 미흡하거나 누락된 경우 보완 요청
- 제출 서류가 완비되면 최종 접수 및 평가수행 단계 진행

2 평가수행 단계

① (서면점검) 금융보안원은 신청기관이 자체점검 후 제출한 보안대책 이행서 및 증거자료 등을 기반으로 서면점검 실시

○ 필요 시 금융보안원은 신청기관에 추가 자료 또는 설명을 요청

※ 서면점검 소요 기간

구분	소요적수 투입 기간
대형	2명 x 5영업일
중형	2명 x 4영업일
소형	2명 x 3영업일

※ 자료 제출 현황 등에 따라 서면점검 및 현장점검 투입 비율 변경 가능

② (현장점검)

① (현장점검 실시) 금융보안원은 보안대책 이행서 및 서면점검 결과를 바탕으로 실제 이행 여부를 육안 실사, 담당자 대면 인터뷰 등의 방법으로 확인

② (결합내역 제공) 금융보안원은 현장점검 결과 결함사항이 발견 되는 경우, 해당 내역을 작성하여 제공

※ 현장점검 소요 기간

구분	소요적수 투입 기간
공통	2명 x 1영업일

※ 자료 제출 현황 등에 따라 서면점검 및 현장점검 투입 비율 변경 가능

③ (확인점검)

※ 결함사항이 없는 경우 확인점검을 생략하고 `③결과통보 단계` 수행

- ① (확인점검 신청) 신청기관은 결함사항을 조치 완료하고, 현장점검 종료 후 60일 이내* <별첨4> 생성형 AI 연계 이용 보안대책 조치 확인 점검 신청서를 금융보안원 앞 제출

* 기한 내 확인점검을 신청하지 않는 경우 확인점검을 생략하고 `③결과통보 단계` 수행

- ② (일정협의) 금융보안원은 신청기관과 확인점검 일정을 협의
- ③ (확인점검 실시) 금융보안원은 보완조치 내역서를 바탕으로 확인 점검을 실시하고, 필요 시 현장실사 수행

3 결과통보 단계

- ① (결과작성) 금융보안원은 현장점검 또는 확인점검 후 결함사항을 포함하여 평가 보고서를 작성하고 신청기관에 송부
- ② (결과검토) 평가에 대한 신뢰성 및 공정성 확보를 위해 금융보안원과 신청기관 간 평가 보고서 상호 검토
- ③ (결과제출) 신청기관은 금융보안원으로부터 제공받은 평가 보고서를 금융위원회 및 금융감독원 앞 제출

4 비용부과 단계

- **(사원기관 회비 부과)** 소요적수를 기반으로 평가비용이 산정되며, 개별업무회비 형태로 부과(비용 확정일이 속한 반기의 다음 반기)
- **(특별참가기관 분담금 부과)** 당해연도 내부망 SaaS 보안대책 평가 업무(생성형 AI 포함) 총 평가비용에 대한 신청기관의 분담금을 산정하여 부과

◇ **특별참가기관당 분담금**

= 당해연도 해당 업무 총 평가비용¹⁾ x 당해연도 해당 특별참가기관 분담률²⁾

1) 당해연도 내부망 SaaS 보안대책 평가업무 총 평가비용(인건비 + 경비 + 전산업무비)

2) 당해연도 해당 특별참가기관 소요적수 ÷ 내부망 SaaS 보안대책 평가업무 총 소요적수

[별첨1]

생성형 AI 연계 이용 보안대책 평가기준

구 분	연번	보안대책
1. 생성형 AI 운영·관리 보안대책 (거버넌스 포함)	1.1	해당 생성형 AI 서비스 활용 전반을 관리·감독하는 책임자(이하 'AI 관리자')를 지정하였는지 여부
	1.2	해당 생성형 AI 서비스 입출력 데이터 로그(입출력데이터 내역 포함)를 기록하고, AI 관리자 등은 중요 정보 유출이나 위험성 등을 감시할 수 있도록 절차가 마련되어 있는지 여부
	1.3	해당 생성형 AI 모델에 대한 취약점이나 문제가 확인될 경우 활용을 즉시 중단하고, 출력값 통제 등 관리 조치를 이행하도록 절차가 마련되어 있는지 여부
	1.4	해당 서비스와 관련되어 있는 사내 임직원을 대상으로 안전한 생성형 AI 활용을 위한 안내 및 정기·수시 교육을 실시하는지 여부
	1.5	해당 생성형 AI 서비스를 금융소비자에게 제공하는 경우 해당 서비스가 생성형 AI를 활용하고 있음을 사전 고지하는지 여부 * 해당 생성형 AI 서비스의 성능을 부풀리거나, 생성형 AI를 적용하지 않는 부분까지 활용하는 것처럼 고지하는 등 부당한 거짓·과장 광고를 하지 않는지 확인
	1.6	안전하고 신뢰할 수 있으며 책임있는 생성형 AI 활용을 위해 자사 여건에 맞는 정책(거버넌스 등)을 마련하여 운영하는지 여부
2. 생성형 AI 모델 보안대책	2.1	상용 생성형 AI 모델 제공자가 적대적 공격 방지 대책을 수립·이행하는지를 확인하는지 여부
	2.2	생성형 AI 모델의 강건성 확보를 위해 필요 보안대책을 마련하여 이행하는지 여부 * 필요 보안대책: 이용자 입·출력값 필터링, 프롬프트에 질의 제한사항 명시, 별도 LLM 모델 추가 사용을 통한 공격 탐지 및 방어 등
	2.3	입출력 데이터를 대상으로 적대적 공격 여부를 확인하고, 적대적 공격에 대비한 대응 방안을 마련하는지 여부
	2.4	개인신용정보 등 중요 정보가 생성형 AI 모델에 입력되지 않도록 방지조치를 이행하는지 여부
	2.5	출력데이터 또는 에러메시지 內 중요 정보나 AI 모델 정보 등이 노출되지 않도록 조치하는지 여부
	2.6	이용자의 생성형 AI 요청 및 결과 출력 횟수 등을 일정 수준 이하로 제한하는지 여부
	2.7	(학습·참조데이터 활용 시) 데이터 위변조 방지를 위한 보안대책을 마련하는지 여부 * 위변조 방지 보안대책: 형상관리, 위변조 방지조치, 이상치 데이터 및 데이터 변조 식별 및 조치 등
	2.8	(추가 학습을 통한 특화 생성형 AI 모델 구축 시) 신규 모델에 대한 위변조 방지 조치 및 적대적 공격 방지 조치를 이행하는지 여부
3. 내부 단말기 보안대책 (모바일 단말 및 관리자 단말기 포함)	3.1	생성형 AI에 질의하는 단말기는 개인신용정보(가명처리 정보는 제외) 등 중요정보가 유출되지 않도록 방지대책* 마련 여부 * (예시) 중요정보 업로드 모니터링 및 차단, 중요정보 암호화 저장, 매체 통제 등
	3.2	생성형 AI 클라우드 관리자 단말기 ↔ 생성형 AI 클라우드 간 인가된 단말기만 접속할 수 있도록 구성하고 있는지 여부
	3.3	생성형 AI 클라우드 관리 콘솔에 대한 비인가 접근 방지를 위한 안전한 인증 방식 적용 여부 * (예시) 관리자 멀티팩터(MFA) 인증 적용, ID별 접근 가능 단말기 지정 등
	3.4	생성형 AI 클라우드 관리자의 활동 내역을 로깅 및 모니터링하고, 이상 징후 발견 시 보안 조치를 이행하는지 여부
4. 내부망 ↔ 외부 AI 모델 연계 네트워크 보안대책 (암호화 등)	4.1	생성형 AI 활용을 위한 '외부망 연계' 구간은 「전자금융감독규정」§60①5에 따라 전용회선 또는 VPN을 사용
	4.2	생성형 AI 활용을 위한 'AI 모델 연계' 구간은 안전한 암호알고리즘을 사용하여 전송자료를 암호화 ※ 안전한 암호 알고리즘 기준은 「KISA 암호 알고리즘 및 키 길이 이용 안내서」등을 참고

[별첨2]

생성형 AI 연계 이용 보안대책 평가 신청서

신청기관	상호명	사업자 등록번호
	주소	
	대표자	전화번호
	총 자산 (전년도 12월 사업보고서 등 기준, 자산 총계액(부채+자본), 단위 백만원)	
	총 임직원 수 (전년도 12월 사업보고서 등 기준, 계약직 포함 직원수 + 임원수)	
	실무 담당자	전화번호
	전자우편(e-mail)	
대상 생성형 AI	서비스명	
	서비스 이용자 수	
	서비스 이용 목적	
	전자금융감독규정 상 업무 구분 ☐ 중요업무 ☐ 비중요업무	

위와 같이 평가를 신청합니다.

년 월 일

신청기관 부서장

(서명 또는 인)

금융보안원장 귀하

첨부서류	1. 혁신금융서비스 지정 관련 결정 통지서 2. [별첨3] 생성형 AI 연계 이용 보안대책 이행서(증거자료 포함)
------	--

[별첨4]

생성형 AI 연계 이용 보안대책 평가 확인점검 신청서

신청기관	상호명	
	대표자	전화번호
	실무 담당자	전화번호
	전자우편(e-mail)	

대상 생성형 AI	서비스명
	결함 총 개수
	결함 잔여 개수
	조치완료 개수

위와 같이 확인점검을 신청합니다.

년 월 일

신청기관 부서장

(서명 또는 인)

금융보안원장 귀하

첨부서류	생성형 AI 연계 이용 보안대책 평가 보완조치 내역서
------	-------------------------------

[별첨5]

생성형 AI 연계 이용 보안대책 평가 보완조치 내역서

신청기관		날짜	년	월	일
평가기준	1.1. 해당 생성형 AI 서비스 활용 전반을 관리·감독하는 책임자(이하 'AI 관리자')를 지정하였는지 여부				
결함내역 및 조치내역	◇ (결함내역) ◇ (조치내역) ※ 보완내역을 상세하게 작성하고 필요 시 증적 자료(실행 화면, 문서, 사진 등)를 첨부, 여러 페이지 작성 가능 ※ 관련 문서 또는 시스템이 있는 경우 작성				
평가기준	4.1. 생성형 AI 활용을 위한 '외부망 연계' 구간은 「전자금융감독규정」 §60①5에 따라 전용회선 또는 VPN을 사용				
결함내역 및 조치내역	◇ (결함내역) ◇ (조치내역) ※ 보완내역을 상세하게 작성하고 필요 시 증적 자료(실행 화면, 문서, 사진 등)를 첨부, 여러 페이지 작성 가능 ※ 관련 문서 또는 시스템이 있는 경우 작성				